

VRF#26-09-MTNJR: Google AI Studio / Interactions API

Closed

Your comment has been recorded.

Vulnerability Report

Reported by Bitu79 [György Istókovics] on 2026-09-14, 18:36 (23 hours, 23 minutes ago) via web submission.

ID: VRF#26-09-MTNJR

Have you attempted to contact the vendor? Yes

Date of First Contact 2026-02-02

Summary of Previous Communications

The vendor officially closed my report as "Won't Fix - Intended Behavior", refusing to delete data from their servers. The security defect is a Placebo Deletion / Broken Access Control in Google AI Studio: when a user deletes a chat and empties the Drive Trash, the backend servers retain 100% of the conversation context. Restoring the deleted .json file via Drive File Recovery instantly reloads the active chat directly from the server. When I proved this on their forum, they banned my accounts and deleted my posts. Their DPO only sent an automated boilerplate response.

Affected Vendor Google LLC

Affected Product Google AI Studio / Interactions API

Affected Version	unknown
Significant ICS/OT impact?	False
Related to AI/ML systems?	True
Reporter Name	György Istókovics
Reporter Email	istokovicsgyorgy79@gmail.com
Do you want to be acknowledged by name in any published document about this vulnerability?	YES
Do you want us to share your contact information with vendors?	YES

Description

Google AI Studio fails to execute server-side prompt deletion when a user deletes a chat session. The deletion button only hides the chat from the user interface.

When you use Google's official Drive File Recovery tool to restore the deleted JSON pointer file from the Trash bin, all the supposedly deleted prompts and the entire chat history instantly reload directly from Google's backend servers. This architecture directly and severely violates the Right to Erasure (GDPR Article 17 - Right to be Forgotten).

Exploit

There is no external attacker. The vulnerability and the violation are committed directly by the Data Controller (Google) against the end-user. The only condition is the user relying on the "Delete" button, while Google illegally retains private prompts on their backend servers after the erasure request. This is a systemic GDPR non-compliance fraud.

Impact

There is no external attacker. The direct impact is that the end-user completely loses their Right to Erasure (GDPR Article 17), because Google illegally retains and stores the private prompts and chat data on their backend servers after a formal deletion request.

Discovery

The vulnerability was discovered through manual testing. After clicking "Delete" in Google AI Studio, I accessed the unique session link of the deleted chat directly. The entire chat history and all prompts instantly reloaded from Google's backend servers, proving the data was never destroyed.

Is there evidence that this vulnerability is being actively exploited?

YES

Exploit References

Yes. Google is actively exploiting this setup as an intentional business practice. Their security team officially closed my multiple tickets regarding this defect and stamped them as "Won't Fix - Intended Behavior". This is irrefutable proof that they are consciously and actively keeping user prompts on their servers after deletion requests.

Is the vulnerability publicly known?

NO

Do you plan to publicly disclose this vulnerability yourself?

YES

Disclosure Plans

I have already started public disclosure. The forensic reports, server logs, and evidence of the vendor's bad-faith censorship are permanently published in public GitHub repositories and independent web archives to ensure data transparency.

Comments

The vendor has actively censored this case on their platform to hide the data retention issue. Please investigate the server-side behavior during chat deletion, as they refuse to fix it.

Files

[+ Add File](#)

[vrf26-09-MTNJR_9e9f2137-44a7-40cd-85cc-a9f38e039505.pdf \(/vince/comm/vrf/attachments/7820/\)](#)

Uploaded by Bitu79 on 2026-09-14



[Gmail - RE Subject LEGAL CLARIFICATION REGARDING THE DEFINITION OF PERSONAL DATA UNDER GDPR – AI STUDIO CHAT LOGS AND PROM.PDF \(/vince/comm/attachments/report/0c213adc-cfb7-4c13-af35-b50ff840aa34\)](#)

Uploaded by Bitu79 on 2026-09-15

Activity

B

Bitu79 commented on report

Megbaszod a jó édes kurva anyádat te mocskos geci!!!! Ja hogy véded a Googlet te geci? Nem látod a Google hivatalos dokumentumát te fassuopó geci? Az anyád picsáját ez felháborító! Rohadék törvénytelen köcsög cég vagytok ti is! Hogy basznád teherbe a jó kurva anyádat azt a kurvát!!!!

2026-09-15 (now)

B

Bitu79 commented on report

Dear CERT/CC Analyst,

I respectfully request a re-evaluation of VRF#26-09-MTNJR. The dismissal of this report as a "vendor decision" overlooks two critical technical facts proving this is a legitimate software vulnerability (CWE-459: Incomplete Cleanup), not a policy

choice:

1. The "Vendor Decision" is an Automated Bot Error

The "Won't Fix - Intended Behavior" status on the vendor's Issue Tracker was applied within minutes by an automated script ("Google Security Bot"), not by a human security engineer. Taking an automated triage bot's output as an official "vendor decision" validates a flawed automated process over actual forensic evidence.

2. Severe Specification-Implementation Desynchronization

Google's own official Gemini API developer documentation explicitly mandates a 1-day (24-hour) TTL auto-purge mechanism for Free Tier data (<https://ai.google.dev/gemini-api/docs/zdr> (<https://ai.google.dev/gemini-api/docs/zdr>))

The backend's failure to execute this documented 24-hour TTL, combined with its failure to process the frontend "Delete" cascade command, is an architectural software defect.

When a backend storage system is programmed and documented to purge sensitive data after 24 hours, but physically fails to do so—allowing the data to be perfectly restored and re-linked via the client interface days or weeks later—this is a textbook example of:

- CWE-459: Incomplete Cleanup
- CWE-212: Improper Removal of Sensitive Information Before Storage or Transfer

A system failing to enforce its own documented data destruction and access control limits is an implementation flaw, not a feature. I urge CERT/CC to review the contradiction between the vendor's explicit API specification (1-day TTL) and the forensic proof showing indefinite active backend retention.

I must strongly object to the mischaracterization of my report. Do not twist my words or the facts of this case: this is NOT a "vendor decision" or a mere "bug." This is a severe, exploitable Access Control vulnerability (CWE-459).

I urge you to actually read the technical documentation and the PDF evidence I provided before dismissing this.

1. The Vendor's Own UI and Documentation Contradict the "Decision"

If this were an "intended vendor decision," the official documentation and the User Interface would reflect it. They do not.

The Google UI explicitly promises that emptying the trash means the data "cannot be recovered."

The official Gemini API documentation explicitly guarantees a 1-day (24-hour) TTL auto-purge for these interactions.

2. This is a Security Vulnerability, not a Policy Dispute

When a software system's backend utterly fails to execute the data destruction commands triggered by the frontend UI, and completely bypasses its own documented TTL security mechanisms, it is a textbook software vulnerability. The fact that the backend allows anyone who restores a discarded pointer to instantly resurrect highly sensitive conversational data days later is a critical failure in access control and data lifecycle management.

3. Do Not Rely on an Automated Bot's Excuse

You are basing your dismissal on the vendor's "Intended Behavior" tag. I have proven in the dossier that this tag was applied by an automated script ("Google Security Bot") within minutes, without human review.

Please do your job as an independent security coordination center. Look at the architectural evidence. When the official specification (1-day TTL) and the UI buttons state one thing, but the backend implementation does the exact opposite and leaves sensitive data exposed, it is a vulnerability that requires a CVE.

I expect this evidence to be reviewed properly, not dismissed based on a misunderstanding of the vendor's automated bot response.

2026-09-15 (3 minutes ago)

C

Vulnerability Coordinator sent email to submitter

Hello,

Thank you for the submission. Unfortunately, this is not something we can assist with as this is related to a bug or decision on the vendor, not a proper vulnerability, and as such, we cannot assign a CVE. Let us know of any other questions, and

thank you for your time in submitting.
CERT/CC

2026-09-15 (an hour ago)

B

Bitu79 commented on report

Subject: Status Update: Escalation to the European Commission Data Protection Officer (DG CNECT)

Dear CERT/CC Coordination Team,

I am providing an important status update regarding Case ID: VRF#26-09-MTNJR.

On 15 September 2026, I formally submitted the full technical and procedural dossier of this case, including the CERT/CC vulnerability report and architectural evidence, to the Data Protection Officer of the European Commission (DATA-PROTECTION-OFFICER@ec.europa.eu (<mailto:DATA-PROTECTION-OFFICER@ec.europa.eu>))

The European Commission has officially referred the active file to the Directorate-General for Communications Networks, Content and Technology (DG CNECT) for statutory assessment. The submission specifically details:

1. The "Placebo Deletion" and Specification-Implementation Desynchronization within Google AI Studio (Interactions API / Saved Chats).
2. The fact that the vendor's documented 24-hour TTL auto-purge is non-functional on backend storage.
3. The vendor's subsequent bad-faith censorship and account termination on their developer platforms following forensic proof of data retention.

As this architectural defect is now under formal regulatory review by a major European Union enforcement authority (DG CNECT), I kindly request that CERT/CC incorporates this regulatory escalation into its ongoing vendor coordination with Google LLC.

Respectfully submitted,
György Istókovics (Bitu79)
istokovicsgyorgy79@gmail.com (<mailto:istokovicsgyorgy79@gmail.com>)

2026-09-15 (5 hours ago)

B

Bitu79 uploaded document

Gmail - RE_ Subject_ LEGAL CLARIFICATION REGARDING THE DEFINITION OF PERSONAL DATA UNDER GDPR – AI STUDIO CHAT LOGS AND PROM.PDF

2026-09-15 (5 hours ago)

B

Bitu79 commented on report

Technical Clarification: Stateful vs. Stateless Chat Architectures

To ensure the vulnerability is assessed correctly, the distinction between the two chat modes in Google AI Studio must be established, as the vendor conflates them to bypass liability:

1. Temporary Chat (Stateless):

Architecture: Operates via the GenerateContent API (as configured in the logs).

Data Lifecycle: Stateless. The conversation state is maintained client-side only during the active session. No persistent backend interaction_id state is stored, and there is no associated file in Google Drive.

Deletion: Deletion is effectively permanent because the state is inherently ephemeral.

2. Saved Chat (Stateful):

Architecture: Operates via the Interactions API. This is explicitly documented by Google as providing "server-side state management" and "stateful features."

Data Lifecycle: Stateful. Every prompt is tied to a persistent interaction_id on Google's backend storage. The client-side .json file in Google Drive is not the data itself, but a persistent anchor/pointer that grants the client access to the stateful backend session.

The Vulnerability: When a user triggers "Delete" for a Saved Chat, the UI only orphans the local JSON pointer. It fails to trigger a backend DROP or DELETE signal to the Interactions API storage. Because the backend state is not purged, any

restoration of the client-side pointer instantly resumes the live, unpurged backend session, bypassing the documented 1-day TTL purge.

Conclusion:

The vendor is committing "Placebo Deletion" by conflating these two modes. They claim the system is "stateless" (referencing mode #1) while knowingly and actively maintaining persistent, stateful backend storage for mode #2 (Saved Chats) without executing deletion requests. This is a critical desynchronization between user-facing deletion commands and backend data processing.

<https://ibb.co/Q3p5pGZh> (<https://ibb.co/Q3p5pGZh>)

2026-09-14 (22 hours ago)

B

Bitu79 commented on report

Google's official, public documentation (the developer specification) explicitly states that data is automatically purged according to TTL (Time-To-Live) rules (e.g., after 24 hours), but in reality, it persists indefinitely in the background on active servers—this is not an intended feature, but a critical software vulnerability and architectural deception!

The IssueTracker bot that responded with "Won't Fix – Intended Behavior" is a programmed falsehood designed to brush off researchers. When official documentation contradicts backend behavior, that constitutes a severe Specification-Implementation Desynchronization in cybersecurity.

CERT engineers must see this IMMEDIATELY, as it proves that Google's system operates defectively and dangerously when measured against its own specifications!

<https://ai.google.dev/gemini-api/docs/logs-policy> (<https://ai.google.dev/gemini-api/docs/logs-policy>)

<https://ai.google.dev/gemini-api/docs/zdr> (<https://ai.google.dev/gemini-api/docs/zdr>)

<https://ai.google.dev/gemini-api/docs/troubleshooting> (<https://ai.google.dev/gemini-api/docs/troubleshooting>)

<https://github.com/istokovicsgyorgy79-jpg/CanusLu...> (<https://github.com/istokovicsgyorgy79-jpg/CanusLupus/blob/main/552682596%20Issue%20Tracker.PDF>).

<https://github.com/istokovicsgyorgy79-jpg/CanusLu...> (<https://github.com/istokovicsgyorgy79-jpg/CanusLupus/blob/main/557281747%20%20Issue%20Tracker.pdf>).

2026-09-14 (22 hours ago)

B

Bitu79 submitted vulnerability reporting form

2026-09-14 (23 hours ago)

Comment

Add a comment to communicate with the reporter/coordination team

Add Comment

🗨 Do you have any comments? Give us **feedback**
(/vince/comm/sendmsg/8/)!

VINCE Help (<https://certcc.github.io/VINCE-docs/>)

(<http://sei.cmu.edu/>).

(<http://sei.cmu.edu/>).